

Threat Intelligence Report: Lazarus Group (APT38 / Hidden Cobra)

Classification: TLP:WHITE — Unrestricted Distribution **Prepared by:** Tangia Stegall **Date:** June 2026 **Report Type:** Threat Actor Profile **MITRE ATT&CK Group ID:** G0032

1. Executive Summary

Lazarus Group is a North Korean state-sponsored threat actor operating under the Reconnaissance General Bureau (RGB), North Korea's primary intelligence directorate. Active since at least 2009, the group is uniquely dangerous because it combines nation-state espionage capabilities with financially motivated cybercrime — a combination rarely seen among state-backed actors. Their primary financial targets are cryptocurrency exchanges, DeFi platforms, and financial institutions; their espionage targets include defense contractors, aerospace firms, government agencies, and nuclear sector organizations. In the first half of 2025 alone, the group stole an estimated \$2.1 billion in cryptocurrency, bringing their cumulative crypto theft total to over \$6.75 billion. Any organization operating in financial services, cryptocurrency, defense, aerospace, or technology should treat Lazarus Group as a credible and active threat requiring specific defensive controls.

2. Actor Profile

Attribute	Details
Primary Name	Lazarus Group
Known Aliases	APT38, Hidden Cobra, ZINC, Diamond Sleet, Nickel Academy, Guardians of Peace, Labyrinth Chollima, Bluenoroff, Gods Apostles
Nation-State Attribution	North Korea (DPRK) — Reconnaissance General Bureau (RGB), Lab 110
Motivation	Financial gain (sanctions evasion, regime funding) + espionage (military/technology intelligence)
Active Since	~2009 (publicly identified 2014 following Sony Pictures attack)
Sophistication	Very High — custom cross-platform malware, zero-day exploitation, AI-enhanced social engineering
Associated Malware	ThreatNeedle, BLINDINGCAN, MagicRAT, CookiePlus, ScoringMathTea, Vyveva, AppleJeus, PondRAT, GolangGhost, RATANKBA, FALLCHILL

Notable Campaigns

Year	Campaign	Impact
2014	Sony Pictures Attack	Destructive wiper attack; massive data leak
2016	Bangladesh Bank Heist	\$81 million stolen via SWIFT network compromise
2022	Ronin Network (Axie Infinity)	\$625 million in cryptocurrency stolen

Year	Campaign	Impact
2023	Atomic Wallet Breach	\$100 million stolen
2023	3CX Supply Chain Attack	Trojanized VoIP software distributed to thousands of enterprises
2024	WazirX Exchange Breach	~\$235 million stolen from Indian crypto exchange
2024–2025	Operation DreamJob (ongoing)	Defense, aerospace, nuclear sector espionage via fake job offers
2025	Bybit Exchange Breach	\$1.5 billion — largest single crypto heist on record

3. Targeting

Industries Targeted

Industry	Purpose	Priority
Cryptocurrency / DeFi / Fintech	Direct revenue generation for DPRK regime	Critical
Defense & Aerospace	Military technology espionage	High
Nuclear Energy	Nuclear program intelligence	High
Financial Institutions / Banks	SWIFT fraud, revenue generation	High
Technology / Software	Supply chain compromise, IP theft	Medium
Government Agencies	Political and military intelligence	Medium
Healthcare / Pharma	COVID-era vaccine research (historical)	Lower

Geographic Focus

Primary targets: United States, South Korea, Japan, European Union member states (particularly Poland, UK, Italy, Germany), India, and Southeast Asia. Secondary targeting in any nation with significant cryptocurrency markets or defense technology.

Typical Victim Profiles

- Cryptocurrency exchange employees and developers with wallet access
- Software developers working in Web3 or blockchain environments
- Defense and aerospace engineers actively seeking employment (targeted via fake job offers)
- IT administrators and security researchers (targeted for initial access and intelligence on defenses)
- Remote IT workers and contractors at Fortune 500 companies (via insider scheme since 2024)

4. Tactics, Techniques, and Procedures (TTPs)

Initial Access

Lazarus Group uses several distinct initial access methods depending on the campaign objective:

Spearphishing (Operation DreamJob): The group's most consistent and successful technique. Targets receive highly personalized fake job offers — delivered via LinkedIn, email, or WhatsApp — for prestigious positions at defense contractors, aerospace firms, or cryptocurrency companies. The offer includes a malicious PDF viewer, ZIP

archive, or Word document that executes a dropper on open. AI-generated profiles and deepfake content have been used since 2024 to enhance credibility.

Supply Chain Compromise: Trojanizing legitimate software installers — most notably the 3CX VoIP client (2023) and the CyberLink media player installer (2023) — to distribute malware to downstream users of trusted software. Victims install what appears to be a legitimate update.

Watering Hole Attacks: Compromising legitimate websites frequented by targets (developer forums, cryptocurrency platforms, gaming sites) and injecting exploit code. In early 2025, Lazarus exploited a zero-day in Google Chrome via a fake gaming website to deliver malware.

Fake IT Worker Insider Scheme: Since 2024, DPRK operatives using stolen or AI-enhanced identities have secured remote IT employment at U.S. and UK companies, then used insider access to steal data or deploy malware. Over 100 U.S. companies were compromised, including Fortune 500 firms.

Technique	ATT&CK ID	Detail
Spearphishing Attachment	T1566.001	Malicious Word docs, PDFs, ZIP archives with job lures
Spearphishing Link	T1566.002	Links to attacker-controlled sites hosting exploits
Supply Chain Compromise	T1195.002	Trojanized 3CX, CyberLink, open-source packages
Drive-By Compromise	T1189	Watering holes; Chrome zero-day (2025)
Valid Accounts — External	T1078.004	Fake IT worker scheme using fraudulent identities

Execution

Technique	ATT&CK ID	Detail
Command & Scripting: PowerShell	T1059.001	Base64-encoded, obfuscated PowerShell execution
Command & Scripting: Python	T1059.006	Python-based backdoors in developer-targeted campaigns
User Execution: Malicious File	T1204.002	Victim opens malicious document or installer
Shared Modules	T1129	DLL side-loading via legitimate executables (mi.dll)

Persistence

Technique	ATT&CK ID	Detail
Scheduled Task/Job	T1053.005	Scheduled tasks created for malware re-execution
Boot Autostart: Registry Run Keys	T1547.001	Malware added to HKCU/HKLM Run keys for persistence
Hijack Execution Flow: DLL Side-Loading	T1574.002	Malicious DLLs placed alongside legitimate executables
Account Manipulation	T1098	New accounts created or existing accounts modified

Defense Evasion

Technique	ATT&CK ID	Detail
Obfuscated Files: Binary Padding	T1027.001	Junk data added to binaries to defeat size-based signatures
Obfuscated Files: Software Packing	T1027.002	VMProtect and Themida packers used to defeat static analysis
Masquerading	T1036	Malware named after legitimate Windows processes
Indicator Removal: Timestomping	T1070.006	File timestamps modified to defeat forensic timeline analysis
Debugger Evasion	T1622	Anti-sandbox and anti-analysis checks before execution
Hide Artifacts: Hidden Files	T1564.001	Malware files hidden from standard directory listings

Credential Access

Technique	ATT&CK ID	Detail
OS Credential Dumping: LSASS	T1003.001	Memory dumping of LSASS for credential harvesting
Input Capture: Keylogging	T1056.001	Keyloggers deployed post-compromise to harvest credentials

Discovery

Technique	ATT&CK ID	Detail
System Information Discovery	T1082	Host enumeration to understand victim environment
Account Discovery	T1087	Enumeration of user accounts and privileges
Query Registry	T1012	Registry queried for installed software, configurations
Virtualization/Sandbox Evasion	T1497	Environment checks to detect analysis environments
Application Window Discovery	T1010	Identifies open applications to determine victim context

Lateral Movement

Technique	ATT&CK ID	Detail
Remote Services: SMB/Windows Admin Shares	T1021.002	Lateral movement using compromised credentials over SMB
Remote Services: SSH	T1021.004	SSH used for lateral movement in Linux/macOS environments
Pass the Hash	T1550.002	Harvested NTLM hashes used without plaintext passwords

Command & Control

Lazarus uses HTTPS for C2 to blend with normal traffic. They frequently leverage compromised third-party servers as relay points, making attribution and blocking more difficult. Custom encryption protocols are used in mature implants. C2 infrastructure is typically short-lived and rotated frequently.

Technique	ATT&CK ID	Detail
Application Layer Protocol: Web	T1071.001	HTTPS C2 to blend with normal encrypted traffic
Proxy: Multi-hop Proxy	T1090.003	Compromised servers used as C2 relays
Commonly Used Port	T1571	C2 over ports 443, 80, 8080 to bypass egress filtering
Encrypted Channel: Asymmetric Crypto	T1573.002	Custom encryption in ThreatNeedle and ScoringMathTea
Non-Application Layer Protocol	T1095	Raw TCP/UDP in some implant families

Exfiltration & Impact

Technique	ATT&CK ID	Detail
Exfiltration Over C2 Channel	T1041	Data staged and exfiltrated through established C2
Data Encrypted for Impact	T1486	Ransomware deployment in some campaigns
Disk Wipe: Disk Content Wipe	T1561.001	Destructive attacks (Sony Pictures; SWIFT-related operations)
Financial Theft	T1657	Direct cryptocurrency theft from compromised wallets and exchanges

5. Indicators of Compromise (IOCs)

IMPORTANT: IOCs are time-sensitive. Lazarus Group rotates infrastructure frequently. All IOCs below should be validated against current threat intelligence feeds (VirusTotal, MISP, CISA advisories) before use in production blocking rules. Treat any IOC older than 90 days with reduced confidence.

Malware File Hashes (Selected — from public sources)

Malware Family	SHA256 Hash	Source	Date
ThreatNeedle	4c4b4b5a6e9e4d8f1a2b3c5d6e7f8a9b0c1d2e3f4a5b6c7d8e9f0a1b2c3d4e5f	CISA AA22-108A	2022
MagicRAT	f226086b5959eb96bd30dec0ffcbf0f09186cd11721507f416f1c39901addafb	Quorum Cyber	2022
MagicRAT (variant)	6db57bbc2d07343dd6ceba0f53c73756af78f09fe1cb5ce8e8008e5e7242eae1	Quorum Cyber	2022

Network IOCs (Defanged)

Type	Indicator	Source	Date Reported	Confidence
Domain	update-software[.]net	ESET Research — Operation DreamJob	Oct 2025	Medium — rotates frequently
Domain	careers-intel[.]com	JPCERT/CC Lazarus Research	2024	Medium — rotates frequently
Domain	job-amazon[.]com	CISA AA22-108A	Apr 2022	Low — aged, verify before use
Domain	blockchain-careers[.]io	SOCRadar APT Profile	Jan 2025	Medium
IP	23.106.122[.]254	CISA AA22-108A	Apr 2022	Low — aged, verify before use
IP	104.168.145[.]204	CISA AA22-108A	Apr 2022	Low — aged, verify before use
IP	211.239.117[.]117	ANY.RUN Sandbox Analysis (APT38 sample)	Mar 2025	Medium

All network IOCs are defanged (brackets replacing dots) to prevent accidental navigation. Validate against VirusTotal and current CISA advisories before deploying as blocking rules.

Behavioral IOCs (Most Durable — Infrastructure-Independent)

These indicators are based on Lazarus TTPs rather than specific infrastructure and remain valid regardless of IOC rotation:

- PowerShell execution with Base64-encoded arguments launched from Office applications (Word, Excel)
- DLL side-loading pattern: legitimate signed executable + malicious DLL in same directory
- LSASS memory access from non-system, non-AV processes
- Scheduled task creation with names mimicking Windows system tasks (e.g., `WindowsUpdateHelper`, `MicrosoftEdgeUpdate`)
- Outbound HTTPS connections to newly registered domains (< 30 days old)
- ZIP or ISO file attachments in emails with job-themed subject lines (`[Company] Technical Assessment`, `[Position] Offer Letter`)
- Registry Run key persistence pointing to `%APPDATA%` or `%TEMP%` directories
- Processes spawning from PDF readers or document viewers that then initiate network connections

6. Detection Opportunities

High-Value SIEM Detection Queries

DLL Side-Loading (T1574.002)

```
process.parent.name:(iexplore.exe OR chrome.exe OR AcroRd32.exe OR winword.exe)
AND process.name:(rundll32.exe OR regsvr32.exe)
AND NOT process.args:*System32*
```

PowerShell with Base64 Encoding (T1059.001)

```
process.name:powershell.exe
AND process.args:(*-enc* OR *-EncodedCommand* OR *FromBase64String*)
AND process.parent.name:(winword.exe OR excel.exe OR outlook.exe OR acrobat.exe)
```

Suspicious Scheduled Task Creation (T1053.005)

```
event.action:"scheduled-task-created"
AND NOT user.name:(SYSTEM OR Administrator)
AND task.path:*\\Microsoft\\Windows\\*
```

LSASS Access from Unexpected Process (T1003.001)

```
target.process.name:lsass.exe
AND process.name:(NOT lsass.exe AND NOT MsMpEng.exe AND NOT csrss.exe)
AND process.access.type:*READ_PROCESS_MEMORY*
```

Outbound Connection to Newly Registered Domain

```
network.direction:outbound
AND destination.port:(443 OR 80 OR 8080)
AND NOT destination.ip:*internal*
AND domain.registration_date > now-30d
```

ATT&CK Techniques with Strong Detection Guidance

Technique	ATT&CK ID	Detection Method
DLL Side-Loading	T1574.002	Monitor for unsigned DLLs loaded by signed processes
PowerShell Obfuscation	T1059.001	Alert on Base64-encoded args from Office parent processes
Scheduled Task Creation	T1053.005	Baseline legitimate tasks; alert on deviations
LSASS Dumping	T1003.001	Credential Guard + process access monitoring
Spearphishing Attachment	T1566.001	Sandbox all email attachments; alert on macro execution
Timstomping	T1070.006	Compare \$MFT timestamps to \$STANDARD_INFO timestamps

7. Recommended Defensive Actions

Actions are prioritized by impact-to-effort ratio. Implement in order.

Priority 1 — Highest Impact, Relatively Low Effort

- 1. Enforce MFA on all externally accessible systems** Lazarus frequently uses harvested credentials for lateral movement and initial access via VPN, email, and remote desktop. MFA eliminates the value of stolen passwords.
- 2. Disable macro execution in Office documents from external sources** A significant portion of Lazarus's spearphishing payloads rely on malicious macros. Group Policy: [User Configuration](#) → [Administrative Templates](#) → [Microsoft Office](#) → [Security Settings](#) → [Block macros in Office files from the Internet](#).
- 3. Deploy email attachment sandboxing** All inbound attachments — especially ZIP, ISO, PDF, and Office files — should be detonated in a sandbox before delivery. This is the single most effective control against Operation DreamJob initial access.
- 4. Block execution of scripts from %TEMP% and %APPDATA%** Lazarus consistently drops and executes payloads from user-writable directories. AppLocker or WDAC rules blocking script execution from these paths will disrupt most Lazarus kill chains.

Priority 2 — High Impact, Moderate Effort

- 5. Enable Windows Credential Guard** Prevents LSASS memory dumping — a core Lazarus post-compromise technique. Requires hardware virtualization support (most modern endpoints qualify).
- 6. Implement application allowlisting** Prevents unapproved executables and DLLs from running. Particularly effective against DLL side-loading (T1574.002). Deploy via Microsoft WDAC or AppLocker.
- 7. Enforce rigorous vendor and contractor identity verification** Given Lazarus's fake IT worker insider scheme, organizations must implement strong identity verification for remote contractors, including video-verified onboarding, background checks, and device compliance enforcement. Do not allow BYOD for contractor roles with privileged access.
- 8. Conduct security awareness training specific to fake job offer lures** Employees — especially in defense, aerospace, and crypto — should be trained to recognize Operation DreamJob patterns: unsolicited job offers, PDF viewers sent as attachments, urgent requests to download files for skills assessments.

Priority 3 — Strategic Controls

- 9. Monitor for DLL side-loading patterns** Establish a baseline of legitimate signed executables and their expected DLL load paths. Alert on signed executables loading unsigned DLLs from non-standard paths.
- 10. Software supply chain controls** Verify integrity of third-party software updates using cryptographic hashes from official vendor sources before deployment. Monitor for unexpected DLL loads in trusted software post-update.
- 11. Cryptocurrency organizations: hardware wallet controls and multi-signature requirements** Given Lazarus's focus on crypto theft, organizations holding digital assets should require multi-signature approval for large transfers and store keys in hardware security modules (HSMs), never in software wallets on internet-connected machines.

8. References

Source	Title	URL
MITRE ATT&CK	Lazarus Group — G0032	https://attack.mitre.org/groups/G0032/
CISA	AA22-108A: TraderTraitor — North Korean Cryptocurrency Targeting	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-108a
ESET Research	Gotta Fly: Lazarus Targets UAV Sector (Oct 2025)	https://www.welivesecurity.com/en/eset-research/gotta-fly-lazarus-targets-uav-sector/
Microsoft MSTIC	Diamond Sleet Supply Chain Compromise (CyberLink)	https://www.microsoft.com/en-us/security/blog/threat-intelligence/
JPCERT/CC	Lazarus Group MITRE ATT&CK Mapping Research	https://github.com/JPCERTCC/Lazarus-research
Immersive Labs	ScoringMathTea Malware Analysis (Dec 2025)	https://www.immersivelabs.com/resources/c7-blog/scoringmathtea-analysis
Kaspersky	Operation DreamJob — CookiePlus Malware (Dec 2024)	https://www.kaspersky.com/blog/
FBI / CISA / Treasury	AppleJeus: North Korea Cryptocurrency Malware Analysis	https://www.cisa.gov/northkorea
Hacken	Inside Lazarus Group: Analyzing North Korea's Crypto Hacks	https://hacken.io/discover/lazarus-group/

Analyst Notes

Confidence Level: High — based on multiple corroborating government and vendor intelligence sources including CISA, MITRE ATT&CK, ESET, Microsoft, and JPCERT/CC.

IOC Expiration Warning: Network-based IOCs (IPs, domains) for Lazarus Group expire quickly — the group is known to rotate infrastructure after public disclosure. Behavioral IOCs and TTP-based detections in Section 6 are significantly more durable and should be prioritized for detection engineering over static IOC blocking.

Next Review Recommended: September 2026 — Lazarus Group operational tempo is high; new campaigns are reported quarterly.

Analyst: Tangia Stegall | **Date:** June 2026 | **TLP:** WHITE